

TEACHING AND EVALUATION GUIDE

AuthLab Facilitator Guide

Delivery · answers · evidence · troubleshooting

A/ AuthLab

Learn Passwords Phishing Passkeys Results

Device-local - v2.0.0

04

MFA AND PASSKEYS · LO-04-LO-06

Replay resistance is not phishing resistance

Threat assumptions: the attacker has a leaked password and may run a real-time adversary-in-the-middle phishing site.

METHOD	REPLAY RESISTANCE	PHISHING RESISTANCE	RECOVERY / DEVICE RISK	USABILITY / DEPLOYMENT ASSUMPTION
Password only	No — captured proof can be replayed	No — a fake verifier can collect it	Recovery and reuse may bypass controls	Password manager and rate limiting assumed
Password + SMS OTP	Limited — code is short-lived	No — code can be relayed in real time	Telecom and recovery paths remain	Phone coverage and number control assumed
Password + TOTP	Limited — short validity window	No — entered codes can be relayed	Seed recovery and device loss remain	Clock sync and authenticator access assumed
Password + push approval	Usually — approval is transaction-bound only if designed so	Not inherent — fatigue and session relay remain	Recovery and enrolled-device control remain	Clear context and number matching assumed

Course COMP6441 Security Engineering**Student** Name: _____ zID: _____**Audience** Facilitators teaching university students or security beginners**Prepared** 20 July 2026

Integrity rule

Do not report participant outcomes without genuine consented records. A developer self-test, screenshot or empty analysis run is technical evidence only.

Session plan and timing

Stage	Target	Facilitator action
Information + consent	3 min	Read the script; answer questions; assign/confirm code.
Form A	5 min	No coaching and no answer revelation.
Modules 1–4	15–20 min	Observe navigation; use neutral prompts only.
Form B + feedback	7 min	Allow review only after submission.
Export / deletion	3 min	Participant chooses; confirm local deletion if requested.

Consent script

AuthLab is an educational activity about authentication. Participation and export sharing are voluntary. Do not enter a real password, MFA code, account name or personal detail. The site keeps progress on this device and does not send learning records to the host. You may skip the optional browser credential demonstration, stop at any time and delete the local session. If you share an export, it is de-identified but not guaranteed anonymous when combined with outside context. Do you understand and choose to continue?

Participant code

Use a random code that does not encode initials, zID, email, date of birth or order known to others. Do not retain a re-identification key unless a separately approved protocol requires one.

Answer key and rationales

Objective	Form A	Form B	Rationale
LO-01	A-01 B	B-01 C	Authentication checks accepted proof; authorisation governs permitted action.
LO-02	A-02 A	B-02 A	A reused password remains replayable at another verifier.
LO-03	A-03 B	B-03 A	Pixels are copyable; origin/domain and a trusted route identify context.
LO-04	A-04 A	B-04 B	A short lifetime does not prevent real-time relay.
LO-05	A-05 B	B-05 A	The RP stores public-key material; the authenticator protects private-key material.
LO-06	A-06 B	B-06 A	The ceremony binds output to the intended relying party.

Major distractors

- Identity is not the same as permission; a correct account can still receive excessive authority.
- Logos, colours and sender display names are presentation evidence, not cryptographic verifier evidence.
- TOTP is not a public key and is not inherently phishing-resistant merely because it expires.
- A relying party does not need a biometric image or passkey private key; local verification stays with the platform/authenticator.
- Verifier-name binding is a protocol property; password rotation and hidden interface elements do not create it.

Module teaching notes

Module	Checkpoint answer	Neutral probe / misconception
1 · Three decisions	Authorisation	'Which decision controls the action after sign-in?' Do not accept 'login failed'.
2 · Credential stuffing	Unique proof stopped replay at PhotoCloud	Complexity does not remove reuse; require one user and one system control.
3 · Phishing	Use registered domain/context/trusted route	Correct spelling or logo is insufficient; ask who receives the proof.
4 · Passkeys	RP binding prevents look-alike assertion	Require one residual risk: device, recovery, implementation or authorisation.

Optional WebAuthn

The conceptual activity is sufficient. Before any API demo, confirm informed consent. Explain that the site does not perform production server verification and that the user may cancel safely.

Scoring and data handling

Score each form out of six using the answer key. Calculate $B - A$ and retain every result, including zero or negative differences. Confidence is a subjective 1–5 rating and must not be merged into the knowledge score. Scenario decisions and usefulness/feedback are separate measures.

Data-handling process

1. Confirm activity_version 2.0.0 and schema_version 2 before analysis.
2. Accept only files deliberately shared by participants; do not copy browser storage without permission.
3. Store exports in a restricted folder and never add names, emails, zIDs, IPs or exact timestamps.
4. Run evaluation/analyse_exports.py on the genuine export directory; retain reject reasons.
5. Report descriptive counts, mean, median, differences and item/LO correctness without significance claims for a small sample.
6. Delete raw exports according to the agreed retention plan and document the action.

Current status

No genuine participant records were supplied. Leave all result tables blank until a real session occurs.

Troubleshooting and accessibility

Issue	Response
Progress did not update	Complete the module checkpoint; opening a section is not completion.
Form A shows no score	Expected: answers are recorded and feedback is withheld until Form B.
WebAuthn unsupported/cancelled	Use the conceptual ceremony; cancellation is a valid safe outcome.
Old/corrupt local session	Use Delete local session or allow the version validator to reset it.
CSV opens with altered text	A leading apostrophe is intentional formula-injection protection.
Small screen	Use mobile module navigation; tables scroll horizontally within their labelled region.
Keyboard or assistive technology barrier	Record the control, browser/AT and impact; provide a paper workbook and do not claim accessibility was proven.

Observation notes

Participant code: _____ Activity version: _____ Browser/device (optional, non-identifying): _____

Misconception or barrier observed: _____

Neutral prompt used: _____

Participant suggestion (verbatim only with permission): _____

Evaluation protocol and reporting

- Recruit only under the course/ethics process and avoid coercion.
- Use the same script and sequence for each participant.
- Do not reveal Form A answers or coach test items.
- Distinguish technical verification from human outcomes in every chart and claim.
- Discuss convenience sample, self-selection, practice effect, facilitator influence, no retention test, simplified scenarios and platform variation.
- Escalate unexpected disclosure of personal data; do not place it in the project repository.

Primary references

1. NIST SP 800-63B-4. Final, July 2025; accessed 20 July 2026. <https://pages.nist.gov/800-63-4/sp800-63b.html>
2. *Web Authentication Level 3*. W3C Candidate Recommendation Snapshot, 26 May 2026; accessed 20 July 2026. <https://www.w3.org/TR/webauthn-3/>
3. *Phishing Guidance: Stopping the Attack Cycle at Phase One*. CISA et al., March 2025; accessed 20 July 2026. <https://www.cisa.gov/sites/default/files/2025-03/Phishing%20Guidance%20-%20Stopping%20the%20Attack%20Cycle%20at%20Phase%20One%20508.pdf>